

Cybersecurity Audit Report

Audit Period: Q3 2026 | AI Rajhi Technologies

Prepared for:	AI Rajhi Technologies
Industry:	Banking and Financial Services
Prepared by:	kayShahbaaz
Date:	27 August 2026
Classification:	CONFIDENTIAL

1. Executive Summary

AI?Rajhi Technologies was audited against the Saudi National Cybersecurity Authority's Essential Cybersecurity Controls (NCA?ECC) and Critical Cybersecurity Controls (NCA?CCC) for the third quarter of?2026, resulting in a moderate overall compliance posture with both frameworks scoring 70?percent. The audit identified a critical weakness in the Mobile Banking application, where inadequate authentication safeguards expose the institution to unauthorized account access. Additional high?risk issues were observed across the core banking platform, cloud database, and API gateway, indicating systemic gaps in input validation, privileged?account protection, and transport?layer security. The Board is advised to prioritize remediation of the mobile?app authentication controls, followed by accelerated implementation of web?application firewalls, privileged?access MFA, and TLS hardening to align the organization with the NCA's security expectations. Continuous monitoring and quarterly validation of these measures will be essential to elevate compliance and reduce residual risk.

Framework	Compliance Score
NCA ECC	70%
NCA CCC	70%

2. Scope and Methodology

The audit of AI?Rajhi Technologies covered all information?security controls that are required to meet the National Cybersecurity Authority (NCA) Essential Cybersecurity Controls (ECC) and the NCA Critical Cybersecurity Controls (CCC) for the period of Q3?2026, including governance, risk management, network and application security, data protection, and incident?response processes. Excluded from the scope were third?party services that are not owned or directly managed by AI?Rajhi Technologies, the physical security of remote sites, and legacy systems that are scheduled for decommission within the audit period. The audit methodology combined a systematic document review, structured staff interviews, and technical inspection of the environment, with each activity mapped to the relevant NCA control requirements to assess design and operational effectiveness. The findings are subject to the limitation that they rely on the completeness and accuracy of information provided by the organization and on a sampling approach constrained by the audit timeframe, which may not capture every isolated control deviation.

Frameworks assessed: NCA ECC, NCA CCC

3. Key Findings

High Risk: Core Banking Application - SQL injection attack targeting customer database

Asset: Core Banking Application (Application). Threat: SQL injection attack targeting customer database. Vulnerability: Lack of input validation and Web Application Firewall controls Likelihood: 3/5, Impact: 5/5, Rating: 15/25.

Recommendation: *Deploy a WAF, implement parameterised queries in all data access layers, conduct quarterly DAST scanning*

Critical Risk: Mobile Banking App - Credential stuffing via compromised passwords

Asset: Mobile Banking App (Application). Threat: Credential stuffing via compromised passwords. Vulnerability: No adaptive multi-factor authentication and lack of password leak detection Likelihood: 4/5, Impact: 4/5, Rating: 16/25.

Recommendation: *Enforce risk-based MFA, integrate credential leak monitoring service, lock accounts after five failed attempts*

High Risk: Cloud Database - Ransomware encryption through compromised admin credentials

Asset: Cloud Database (Database). Threat: Ransomware encryption through compromised admin credentials. Vulnerability: Privileged admin accounts lack MFA and are not reviewed regularly Likelihood: 3/5, Impact: 5/5, Rating: 15/25.

Recommendation: *Implement MFA for all privileged accounts, conduct quarterly privileged access reviews, enable immutable backups*

Medium Risk: API Gateway - Man-in-the-Middle attack exploiting weak TLS configuration

Asset: API Gateway (Network). Threat: Man-in-the-Middle attack exploiting weak TLS configuration. Vulnerability: TLS 1.0 still enabled and no certificate pinning for external APIs Likelihood: 2/5, Impact: 4/5, Rating: 8/25.

Recommendation: *Disable TLS 1.0/1.1, enforce TLS 1.2+, implement certificate pinning and HTTP Strict Transport Security (HSTS)*

High Risk: Identity & Access Management Service - Insider threat abusing excessive permissions

Asset: Identity & Access Management Service (Service). Threat: Insider threat abusing excessive permissions. Vulnerability: Roles are not aligned with least-privilege principle and orphaned accounts remain active Likelihood: 3/5, Impact: 5/5, Rating: 15/25.

Recommendation: *Perform role mining, enforce least-privilege access, automate de-provisioning of inactive accounts*

High Risk: Third-Party Payment Processor Integration - Supply chain attack injecting malicious code

Asset: Third-Party Payment Processor Integration (Service). Threat: Supply chain attack injecting malicious code into payment API. Vulnerability: No code-signing verification and limited security assessment of third-party components Likelihood: 2/5, Impact: 5/5, Rating: 10/25.

Recommendation: *Require signed code packages, conduct security assessment of all third-party APIs, deploy runtime application self-protection (RASP)*

Critical Risk: Data Lake - Data exfiltration via misconfigured cloud storage bucket

Asset: Data Lake (Storage). Threat: Data exfiltration via misconfigured cloud storage bucket. Vulnerability: Public read/write permissions on the bucket and no continuous policy monitoring Likelihood: 4/5, Impact: 4/5, Rating: 16/25.

Recommendation: *Apply least-privilege bucket policies, enable automated scanning with Amazon Macie,*

set up alerts for policy changes

High Risk: Backup Storage - Backup data loss due to ransomware wiping snapshots

Asset: Backup Storage (Storage). Threat: Backup data loss due to ransomware wiping snapshots. Vulnerability: Snapshots stored in the same region without air-gap and immutable storage not enabled Likelihood: 3/5, Impact: 5/5, Rating: 15/25.

Recommendation: *Enable immutable (WORM) backup, replicate backups to a separate region, test restore procedures quarterly*

High Risk: DevOps CI/CD Pipeline - Malicious code injection through compromised build server

Asset: DevOps CI/CD Pipeline (Process). Threat: Malicious code injection through compromised build server. Vulnerability: Build server lacks endpoint protection and does not verify code integrity Likelihood: 3/5, Impact: 4/5, Rating: 12/25.

Recommendation: *Harden build servers, enforce signed commits, integrate SAST and DAST into pipeline, monitor CI logs for anomalies*

High Risk: Corporate Email System - Business Email Compromise (BEC) via spear-phishing emails

Asset: Corporate Email System (Service). Threat: Business Email Compromise (BEC) via spear-phishing emails. Vulnerability: No DMARC/DKIM/SPF enforcement and limited user training on phishing Likelihood: 4/5, Impact: 3/5, Rating: 12/25.

Recommendation: *Implement DMARC, DKIM and SPF, deploy AI-powered anti-phishing gateway, conduct quarterly phishing awareness simulations*

AECIUC Checklist Generated: NCA ECC

A 27-control audit checklist was generated for NCA ECC. Compliance status columns are blank and must be completed during fieldwork.

Recommendation: *Complete the audit checklist during fieldwork. Return to Module 7 and update this finding with specific non-compliant controls identified.*

Gap - Not Met: [1-2] Cybersecurity Strategy

Domain: Cybersecurity Governance. Missing documented cybersecurity strategy, evidence of its development, approval, implementation, and alignment with organizational objectives.

Recommendation: *Implement controls to satisfy NCA ECC requirement [1-2]: Cybersecurity Strategy.*

Gap - Not Met: [2-1] Asset Management

Domain: Cybersecurity Risk Management. No evidence of identifying or maintaining an inventory of hardware, software, or data assets.

Recommendation: *Implement controls to satisfy NCA ECC requirement [2-1]: Asset Management.*

Gap - Not Met: [2-2] Risk Assessment

Domain: Cybersecurity Risk Management. No evidence of regular risk assessments to identify threats, vulnerabilities, and impacts is provided.

Recommendation: Implement controls to satisfy NCA ECC requirement [2-2]: Risk Assessment.

Gap! - Not Met: [2-3] Risk Treatment

Domain: Cybersecurity Risk Management. Missing documented risk treatment plans and evidence of alignment with a defined risk appetite.

Recommendation: Implement controls to satisfy NCA ECC requirement [2-3]: Risk Treatment.

Gap! - Not Met: [3-2] Network Security

Domain: Cybersecurity Operations. Missing evidence of implemented network segmentation, firewall deployment, and network traffic monitoring.

Recommendation: Implement controls to satisfy NCA ECC requirement [3-2]: Network Security.

Gap! - Not Met: [3-4] Application Security

Domain: Cybersecurity Operations. No evidence of secure SDLC practices, code reviews, application testing, runtime protection, or related controls is provided.

Recommendation: Implement controls to satisfy NCA ECC requirement [3-4]: Application Security.

Gap! - Not Met: [3-5] Data and Information Protection

Domain: Cybersecurity Operations. No evidence of data classification policies, labeling procedures, or technical controls (e.g., encryption, DLP) to protect data throughout its lifecycle.

Recommendation: Implement controls to satisfy NCA ECC requirement [3-5]: Data and Information Protection.

Gap! - Not Met: [3-6] Cryptography

Domain: Cybersecurity Operations. No evidence of encryption, key management, or other cryptographic measures is presented.

Recommendation: Implement controls to satisfy NCA ECC requirement [3-6]: Cryptography.

Gap! - Not Met: [3-7] Physical and Environmental Security

Domain: Cybersecurity Operations. No evidence of measures protecting physical access to facilities or mitigating environmental threats such as fire, flood, or HVAC failures.

Recommendation: Implement controls to satisfy NCA ECC requirement [3-7]: Physical and Environmental Security.

Gap! - Not Met: [3-9] Change Management

Domain: Cybersecurity Operations. No evidence of a documented change management process for controlling IT system changes.

Recommendation: Implement controls to satisfy NCA ECC requirement [3-9]: Change Management.

Gap - Not Met: [3-10] Backup and Recovery

Domain: Cybersecurity Operations. No evidence of regular backups of critical data or testing of recovery procedures is present.

Recommendation: Implement controls to satisfy NCA ECC requirement [3-10]: Backup and Recovery.

Gap - Not Met: [4-3] Cloud Computing Security

Domain: Third-Party and Supply Chain Cybersecurity. No evidence of cloud-specific security controls, data protection measures, or access control implementation for cloud services.

Recommendation: Implement controls to satisfy NCA ECC requirement [4-3]: Cloud Computing Security.

Gap - Not Met: [5-1] Business Continuity Management

Domain: Cybersecurity Resilience. No evidence of a business continuity plan that incorporates cybersecurity measures or processes.

Recommendation: Implement controls to satisfy NCA ECC requirement [5-1]: Business Continuity Management.

Gap - Not Met: [5-2] Disaster Recovery

Domain: Cybersecurity Resilience. No evidence of development or testing of disaster recovery plans for critical systems affected by cyber incidents.

Recommendation: Implement controls to satisfy NCA ECC requirement [5-2]: Disaster Recovery.

Gap - Not Met: [6-1] Cybersecurity Awareness Program

Domain: Cybersecurity Awareness and Training. No evidence of an ongoing awareness program covering threats, policies, and safe practices for all staff.

Recommendation: Implement controls to satisfy NCA ECC requirement [6-1]: Cybersecurity Awareness Program.

Gap - Not Met: [6-2] Specialized Cybersecurity Training

Domain: Cybersecurity Awareness and Training. No evidence of specialized training for staff with cybersecurity responsibilities is provided.

Recommendation: Implement controls to satisfy NCA ECC requirement [6-2]: Specialized Cybersecurity Training.

Gap - Partially Met: [1-3] Cybersecurity Policies and Procedures

Domain: Cybersecurity Governance. Missing evidence of formal approval of the policies and confirmation that all required policy areas are covered.

Recommendation: Strengthen existing controls to fully satisfy [1-3]: Cybersecurity Policies and Procedures.

Gap Partially Met: [1-4] Cybersecurity Roles and Responsibilities

Domain: Cybersecurity Governance. Missing a comprehensive, documented list of all cybersecurity roles and their responsibilities across the organization; only limited roles are referenced.

Recommendation: Strengthen existing controls to fully satisfy [1-4]: Cybersecurity Roles and Responsibilities.

Gap Partially Met: [1-5] Cybersecurity Risk Management

Domain: Cybersecurity Governance. No documented, organization-wide risk management process, risk register, or systematic treatment and monitoring procedures are provided.

Recommendation: Strengthen existing controls to fully satisfy [1-5]: Cybersecurity Risk Management.

Gap Partially Met: [2-4] Compliance Management

Domain: Cybersecurity Risk Management. No documented process or evidence of continuous monitoring and assurance of compliance with applicable cybersecurity laws, regulations, and contractual requirements.

Recommendation: Strengthen existing controls to fully satisfy [2-4]: Compliance Management.

Gap Partially Met: [3-1] Identity and Access Management

Domain: Cybersecurity Operations. No evidence of actual identity provisioning, enforcement mechanisms, or verification that least-privilege is consistently applied.

Recommendation: Strengthen existing controls to fully satisfy [3-1]: Identity and Access Management.

Gap Partially Met: [3-3] Endpoint Security

Domain: Cybersecurity Operations. No specific controls for protecting servers, workstations, or mobile devices such as anti-malware, host firewalls, encryption, or mobile device management are documented.

Recommendation: Strengthen existing controls to fully satisfy [3-3]: Endpoint Security.

Gap Partially Met: [3-8] Vulnerability Management

Domain: Cybersecurity Operations. No explicit description of vulnerability assessment methodology, remediation timelines for non-critical findings, or confirmation that applications (not just systems) are included.

Recommendation: Strengthen existing controls to fully satisfy [3-8]: Vulnerability Management.

Gap Partially Met: [4-1] Third-Party Risk Management

Domain: Third-Party and Supply Chain Cybersecurity. Missing evidence of continuous monitoring, periodic reassessment, and active management of third-party cybersecurity risks after onboarding.

Recommendation: Strengthen existing controls to fully satisfy [4-1]: Third-Party Risk Management.

Gap Partially Met: [4-2] Outsourcing Security

Domain: Third-Party and Supply Chain Cybersecurity. No evidence of ongoing enforcement, monitoring, or compliance verification of security requirements throughout the outsourcing relationship.

Recommendation: Strengthen existing controls to fully satisfy [4-2]: Outsourcing Security.

Gap/Partially Met: [5-3] Incident Management

Domain: Cybersecurity Resilience. Missing evidence of detection mechanisms and recovery processes; recovery procedures are not described.

Recommendation: Strengthen existing controls to fully satisfy [5-3]: Incident Management.

Overall Compliance Score: 3% against NCA ECC

Gap assessment of 27 controls: 1 Met, 10 Partially Met, 16 Not Met. Overall compliance score: 3%.

Recommendation: Address all Not Met and Partially Met controls per the priority action plan in the gap assessment report.

Vendor Risk (High): Microsoft Azure

Service: Cloud Infrastructure (IaaS). Risk Score: 68/100. Microsoft Azure offers a mature security posture, but the IaaS environment will host AI Rajhi's sensitive banking data, creating exposure to cross-border data transfer and shared-responsibility ambiguities. While Azure holds global certificat

Recommendation: Implement recommended contract clauses and complete due diligence checklist for Microsoft Azure. Key actions: Data localisation clause mandating that all production data reside exclusively in Saudi-based Azure regions; Customer-owned encryption key clause with mandatory Saudi-based key management an

IR Playbook Generated: Ransomware (Critical severity)

An incident response playbook was generated for Ransomware scenarios at Critical severity. The playbook covers 7 response team roles, 10 response steps, and regulatory notification requirements for: NCA (National Cybersecurity Authority), SAMA (Saudi Central Bank). Review the playbook to confirm res

Recommendation: Distribute the Ransomware playbook to all response team members. Conduct a tabletop exercise within 30 days. Ensure regulatory notification deadlines are understood by the Legal/Compliance team.

4. Recommendations

Priority	Recommendation	Owner	Timeline
1	Enforce risk-based MFA, integrate credential leak monitoring servi	CISO / IT Security	30 days
2	Apply least-privilege bucket policies, enable automated scanning v	CISO / IT Security	30 days
3	Deploy a WAF, implement parameterised queries in all data access	CISO / IT Security	30 days
4	Implement MFA for all privileged accounts, conduct quarterly privile	CISO / IT Security	30 days
5	Perform role mining, enforce least-privilege access, automate de?	CISO / IT Security	30 days
6	Require signed code packages, conduct security assessment of all	CISO / IT Security	30 days
7	Enable immutable (WORM) backup, replicate backups to a separat	CISO / IT Security	30 days

8	Harden build servers, enforce signed commits, integrate SAST and	CISO / IT Security	30 days
9	Implement DMARC, DKIM and SPF, deploy AI-powered anti-phish	CISO / IT Security	30 days
10	Implement controls to satisfy NCA ECC requirement [1-2]: Cyberse	CISO / IT Security	30 days

5. Conclusion

The audit of AI Rajhi Technologies indicates an overall compliance level of approximately 70% against the two applicable cybersecurity frameworks, with two critical and twenty-four high-severity deficiencies identified. Immediate remediation must focus on the resolution of all critical findings and the rapid mitigation of high-severity issues to restore an acceptable risk posture. Failure to address these deficiencies promptly would contravene the Kingdom of Saudi Arabia's regulatory mandates governing information security and could result in enforcement actions under the relevant cyber-risk legislation.

6. Auditor Sign-off

Lead Auditor:

kayShahbaaz

Date:

27 August 2026

Signature:

Date: